



TASK 3 REPORT – Web Application Security Testing

1. Title

Web Application Vulnerability Assessment using DVWA and Burp Suite

2. Introduction

Web applications are widely used in modern systems and are often targeted by attackers due to improper input validation, weak authentication mechanisms, and missing security controls.

This project demonstrates common web application vulnerabilities using DVWA (Damn Vulnerable Web Application) in a controlled lab environment. The objective is to understand how these vulnerabilities work and how attackers exploit them.

3. Objective

The objectives of this experiment are:

- To identify common web application vulnerabilities
- To understand exploitation techniques in a controlled environment
- To analyze HTTP requests using Burp Suite
- To study the impact of insecure coding practices
- To learn basic penetration testing concepts

4. Tools and Environment

Tools Used:

- DVWA (Damn Vulnerable Web Application)
- Burp Suite Community Edition
- Web Browser (Firefox/Chrome)
- Browser Developer Tools

Environment:

- Localhost server (Apache / XAMPP / Linux environment)
- DVWA security level set to Low

5. Vulnerabilities Tested

5.1 SQL Injection

SQL Injection was performed on input fields by injecting malicious SQL queries.

Observation:

- Application did not properly sanitize user input
- Allowed manipulation of backend SQL queries
- Could potentially expose or modify database data

5.2 Reflected Cross-Site Scripting (XSS)

JavaScript payloads were injected into input fields.

Observation:

- Script executed immediately in browser response
- Input was reflected without sanitization

5.3 Stored Cross-Site Scripting (XSS)

Malicious scripts were stored in the application.

Observation:

- Script executed whenever the page was loaded
- Affects multiple users viewing the page

5.4 Cross-Site Request Forgery (CSRF)

Password change functionality was analyzed.

Observation:

- CSRF token protection was absent in low security mode
- Browser restrictions (SameSite cookies) reduce exploit success in modern environments

5.5 Local File Inclusion (LFI)

File inclusion vulnerability was tested using path traversal techniques.

Observation:

- Sensitive file `/etc/passwd` was successfully accessed
- Indicates improper validation of file path input

5.6 Burp Suite – HTTP Interception

Burp Suite was used to intercept HTTP requests.

Observation:

- Login request was captured successfully
- Credentials were visible in plaintext in HTTP request
- Requests were forwarded to complete authentication

5.7 Security Headers Analysis

HTTP response headers were analyzed using browser developer tools.

Observation:

- Important security headers were missing:
 - Content-Security-Policy (CSP)
 - Strict-Transport-Security (HSTS)
 - X-Frame-Options
- Missing headers increase risk of XSS, clickjacking, and MITM attacks

6. Key Findings

- Improper input validation leads to SQL Injection and XSS vulnerabilities
- Lack of CSRF protection allows unauthorized actions
- File inclusion flaws can expose sensitive system files
- Security headers play a critical role in web application protection
- Burp Suite is effective for analyzing HTTP traffic and request behavior

7. Conclusion

This experiment provided practical exposure to common web application vulnerabilities in a controlled environment. It helped in understanding how attackers exploit insecure applications and

emphasized the importance of secure coding practices and proper security configurations.

8. Disclaimer

This project was conducted in a controlled lab environment (DVWA) for educational purposes only. No real-world systems were targeted.